

Relatório Assignment #2 – Fundamentos de Segurança Informática

Realizado por:

Gustavo Roberto
2023215017

Teodoro Maques
2023211717

1. Descrição das Configurações e Implementação da Arquitetura

A infraestrutura foi montada utilizando quatro máquinas virtuais (VMs) em ambiente isolado, focando-se na implementação de uma **Hierarquia de Confiança (PKI)** e na **Validação de Revogação em Tempo Real (OCSP)**.

1.1. Topologia de Rede e Endereçamento

A rede interna opera no segmento 10.60.0.0/24, com a seguinte distribuição de funções:

- **VM 1 (Cliente):** 10.60.0.1. Máquina do utilizador final com o browser Firefox, onde foi importado o certificado de cliente.
- **VM 2 (VPN Gateway):** Router central da rede que gere o tráfego entre segmentos.
- **VM 3 (Web-Server):** 10.60.0.100. Servidor Apache (HTTPD) configurado para exigir autenticação mútua via TLS.
- **VM 4 (Certification Authority & OCSP Responder):** 10.60.0.30. Máquina mestre que detém a Root CA e o serviço de validação OCSP.

1.2. Implementação da Autoridade de Certificação (CA)

A CA privada foi criada na **VM 4** utilizando OpenSSL. O processo incluiu:

1. **Criação da Root CA:** Geração de uma chave RSA de 4096 bits e um certificado auto-assinado (ca.cert.pem) com validade de 20 anos.
2. **Configuração do openssl.cnf:** Edição dos caminhos da base de dados (index.txt) e definições de extensões X.509 necessárias para o suporte a OCSP.
3. **Emissão de Certificados:** Foram emitidos certificados para o servidor Apache e para o cliente final (Cliente-FSI), identificados pelo número de série 1003.

2. Configuração do Servidor Seguro e OCSP

A segurança do servidor web na **VM 3** foi elevada para exigir não apenas a criptografia do tráfego, mas a identificação obrigatória do utilizador.

2.1. Configuração do Apache (mod_ssl)

No ficheiro /etc/httpd/conf.d/ssl.conf, foram implementadas as seguintes diretivas críticas:

- **Autenticação Obrigatória:** SSLVerifyClient require e SSLVerifyDepth 1, forçando o browser a apresentar um certificado válido.
- **Ligação ao OCSP:**
 - SSLOCSPEnable on: Ativa a verificação de revogação.
 - SSLOCSPDefaultResponder http://10.60.0.30:8080: Aponta para o serviço na VM 4.
 - SSLOCSPOverrideResponder on: Garante que o Apache utiliza o responder definido localmente.

2.2. Resolução de Conflitos e Segurança do Sistema

Durante a implementação, foram resolvidos três obstáculos críticos:

1. **Firewall (VM 4):** Abertura da porta 8080/tcp para permitir que o Apache consultasse o responder OCSP (firewall-cmd --add-port=8080/tcp).
2. **SELinux (VM 3):** Por defeito, o SELinux impedia o Apache de realizar ligações externas. Foi corrigido com setsebool -P httpd_can_network_connect 1.
3. **Erro de Cadeia de Revogação:** O Apache exigia ficheiros CRL ao usar SSLCARevocationCheck chain. A solução foi comentar a linha para priorizar exclusivamente o OCSP, garantindo o arranque do serviço.

3. Descrição dos Testes e Validação da Solução

3.1. Validação do Responder OCSP

O servidor OCSP foi iniciado na **VM 4** com o comando:

```
openssl ocsp -index index.txt -port 8080 -rsigner certs/ca.cert.pem -rkey private/ca.key.pem -CA certs/ca.cert.pem -text
```

A conectividade foi validada a partir da **VM 3** usando curl -I http://10.60.0.30:8080, obtendo resposta do serviço.

3.2. Teste de Acesso e Autenticação Mútua

Ao aceder a https://10.60.0.100 na **VM 1**:

1. O Firefox solicitou a escolha do certificado (Cliente-FSI).
2. O Apache contactou a VM 4 em tempo real.
3. **Resultado no Log do OCSP (VM 4):**

Cert Status: good

Serial Number: 1003

4. **Resultado no Browser:** Exibição da página "VPN de Laboratorio: Acesso Concluido com Sucesso!", confirmando que a identidade foi verificada e o certificado não estava revogado.

4. Informações Relevantes e Conclusão

A arquitetura implementada demonstra o ciclo completo de segurança de uma PKI moderna. O uso do protocolo **OCSP** revelou-se superior às tradicionais CRLs, permitindo que o administrador da CA (VM 4) revogue o acesso de um utilizador de forma imediata, refletindo-se no próximo acesso ao servidor web (VM 3).

Ficheiros Relevantes Anexados:

- openssl.cnf: Configuração da CA e OCSP.
- ssl.conf: Configuração do servidor Apache com verificação de cliente.
- index.txt: Base de dados de certificados emitidos.
- ca.cert.pem: Certificado público da autoridade raiz